COMP1629:
Penetration Testing Report

Table of Contents

Executive Summary: 3

High-Level Outcomes: 4

- **Exposed Legacy SSH Service** 4
- **Insecure VPN Configuration:** 4
- **Unencrypted Web-Based VPN Portal:** 4
- **Publicly Accessible Webmin Administrative Interface** 4
- **Outdated Embedded Network Appliance** 4
- **Unsupported Database Service:** 5
- **Client-Side Library with Known Vulnerabilities:** 5
- **Improper HTTP Method Handling on Web Server** 5
- **Default Server Configuration Disclosure** 5

Prioritized Recommendations 6

Test Scope and Methodology 8

Detailed Technical Findings 10

Outdated OpenSSH Service 10

GlobalProtect Portal Served Over HTTP 11

Default IIS Welcome Page Exposed 13

Exposed Webmin Interface with Weak Headers 14

VPN Using IKEv1 Aggressive Mode 16

Outdated DD-WRT Firmware and Services 19

Webmin MiniServ Version Disclosure and Insecure HTTP Methods 20

MySQL Version 5.1.73 Detected 22

jQuery v3.4.1 with Known XSS Risks 23

IIS Server Allows TRACE HTTP Method 24

Attack Chain Summary 25

Conclusion: 26

Executive Summary:

The scope of this test included analysis of exposed services, outdated technologies, administrative interfaces, and potential misconfigurations identified across a series of network captures and screenshots provided for review.

The objective of this assessment was to evaluate the security posture of a representative IT infrastructure by identifying exploitable weaknesses across exposed services, outdated software, and misconfigured systems. The test was carried out ethically, in a non-intrusive manner, and findings are based solely on visual analysis of supplied evidence.

The assessment revealed several high-risk vulnerabilities, including:

- An exposed VPN using IKEv1 Aggressive Mode, vulnerable to offline brute-force attacks
- A GlobalProtect portal accessible over unencrypted HTTP
- Outdated software including OpenSSH v5.3, MySQL v5.1.73, and jQuery v3.4.1
- An administrative Webmin interface with security header misconfigurations
- Microsoft IIS server permitting insecure HTTP methods such as TRACE

These findings were notable by themselves, as they also indicated that there was a distinct attack pattern where it was possible for an attacker to receive VPN credentials, penetrate the organization's internal systems, find unpatched and insecure administrative interfaces and eventually retrieve or make change to sensitive data through publicly available and poorly configured database services. The vulnerable web technology also increased the attack surface for cross-site scripting and session hijacking attacks.

The report outlines each of these findings accompanied by technical evidence, possible impact, and relevant remediation information. Given the level of depth and severity of the vulnerabilities, the overall security posture of the environment has a classification of Critical. The assessment reinforces the importance of proactive patching, secure configuration, and access segmentation in today’s IT landscape.

High-Level Outcomes:

The assessment identified a number of critical security vulnerabilities within network services, web applications, and administrative interfaces. The following high-level results summarizes the key observations gathered from the simulated environment:

- ## Exposed Legacy SSH Service

We discovered an instance of OpenSSH version 5.3 running on network port 22 (See Picture 1) The legacy version has numerous documented vulnerabilities and is using weak encryption protocols, which increases susceptibility to brute force attempts and exploitation from remote attackers.

- ## Insecure VPN Configuration:

The VPN service (See Picture 5) was configured to use Internet Key Exchange version 1 (IKEv1) in Aggressive Mode. This exposes pre-shared key hashes during the handshake exchanging process, which can be easily intercepted and later used for offline brute force attempts, for malicious purposes and could threaten the VPN connection.

- ## Unencrypted Web-Based VPN Portal:

A GlobalProtect portal was identified running over HTTP (See Picture 2). The lack of transport layer encryption represents a serious man-in-the-middle (MITM) threat, which could expose credentials or hijack session tokens while users logged in to the VPN.

- ## Publicly Accessible Webmin Administrative Interface

The Webmin service was found exposed to the network (Pictures 4 and 7), revealing server headers, version information, and lacking essential security controls such as transport encryption and secure HTTP headers. This increases the likelihood of remote administrative compromise.

- ## Outdated Embedded Network Appliance

A DD-WRT firmware-based router (Picture 6) was discovered running an obsolete Linux kernel and embedded OpenSSH service. Devices of this type are commonly exploited as pivot points for internal network traversal or for launching MITM attacks.

- ## Unsupported Database Service:

A MySQL 5.1.73 instance (Image 8) has been found to have unrestricted access on port 3306. This version is end-of-life and contains many critical vulnerabilities such as privilege escalation, authentication bypass, and denial-of-service vulnerabilities.

- ## Client-Side Library with Known Vulnerabilities:

jQuery version 3.4.1 (Picture 9) is a common library for web applications, but also includes well-known cross-site scripting (XSS) vulnerabilities due to insecure ways of manipulating the DOM that makes injection attacks possible, and can lead to session hijacking in client-side applications.

- ## Improper HTTP Method Handling on Web Server

The target IIS 10.0 server (Picture 10) was found to support the TRACE method, which may enable cross-site tracing (XST) attacks in conjunction with other client-side vulnerabilities. Additionally, verbose server headers were disclosed, aiding reconnaissance efforts.

- ## Default Server Configuration Disclosure

The display of the default Microsoft IIS welcome page (Picture 3) indicates a lack of hardening and suggests the web server may be operating with default or incomplete configurations, increasing the risk of fingerprinting and unauthorized access.

Prioritized Recommendations

Outdated OpenSSH Server (Picture 1) – Priority: High

The system was found operating OpenSSH version 5.3, which is extremely old and known to have several security vulnerabilities. Attackers may be able to exploit vulnerabilities in older encryption methods or use brute force attempts to guess login credentials. You should

- upgrade OpenSSH to a patched version (9.x is the most recent version) and
- make sure that you use secure ciphers and protocols (e.g., do not enable SSHv1 and weak key exchange protocols).

GlobalProtect Portal Over HTTP (Picture 2) – Priority: High

The VPN login portal is reachable using an unencrypted HTTP link. An attacker using man-in-the-middle (MITM) techniques will be able to access any credentials that are entered.

- All online authentication portals should be configured to use HTTPS with a valid SSL/TLS certificate.

Default IIS Configuration Exposed (Picture 3) – Priority: Medium

The server displays the default IIS welcome page, which suggests it is running in a default or test configuration. This exposes version information and confirms the presence of a web server to attackers during reconnaissance. It is recommended to

- remove or disable default pages and replace them with custom error messages or production-ready content. This helps reduce information leakage and improves professional security posture.

Exposed Webmin Interface (Pictures 4 & 7) – Priority: High

Webmin is a powerful management tool, and allowing use of it outside of trusted networks without protecting it poses a considerable threat. The interface is not required to have security headers, and may also be using an old version.

- Access should be limited to internal IP addresses or using a VPN.
- Further, it is always good practice to turn on HTTPS and allow MFA if that is feasible to help reduce the risk of unauthorized access.

Insecure VPN Configuration – IKEv1 Aggressive Mode (Picture 5) – Priority: High

The VPN uses IKEv1 in Aggressive Mode, which means the handshake process reveals the hashed credentials. An attacker can use this information to either conduct a brute-force attack or dictionary attack offline. Disabling IKEv1 altogether is optimal and selecting

- IKEv2 or SSL VPNs is suggested, as they will (typically) employ stronger encryption and better authentication methods. Or, if you use the VPN with digital certificates and/or two-factor authentication

Outdated DD-WRT Firmware with SSH (Picture 6) – Priority: Medium

The DD-WRT router has an old version of the kernel of Linux, and it has an old version of OpenSSH, which may include known vulnerabilities (and insecure default users and passwords). Routers are preffered as access points to internal networks. The router must be updated to the most recent version supported, and if the tablet supports SSH access (give it up), if SSH is really required it should only be active when needed (not by standby). There is no different recommendation for the admin login you should choose strong credentials, limit access to internal Ips.

Outdated MySQL Database Service (Picture 8) – Priority: High

MySQL version 5.1.73 is no longer supported, and vulnerable to multiple security threats, including privilege escalation and denial of service attacks. Using obsolete database software can allow attackers to use known vulnerabilities in your software to create access and change data. It is recommended to

- Upgrade to a more current version of MySQL (e.g., 8.x) and to implement appropriate user permissions, encryption at rest, and secure authentication methods.

Vulnerable jQuery Library Detected (Picture 9) – Priority: Medium

The application is using jQuery version 3.4.1, which has various vulnerabilities that can lead to cross-site scripting (XSS) attacks. This can allow an attacker to insert malicious scripts into web pages allowing the attacker to then use these to capture session cookies, or user information.

- All old JavaScript libraries need to be updated to their latest stable release, as determined by developers. Developers should also establish content security policies (CSP) and sanitize all inputs from users.

IIS Server Allows TRACE Method (Picture 10) – Priority: Medium

The Microsoft IIS server was found to have the TRACE HTTP method enabled, which is usually exploited for Cross-Site Tracing (XST) attacks in conjunction with XSS. TRACE simply sends the input back to the client, along with the headers, which in turn can lead to cookie theft. Clearly, this approach needs to be explicitly disabled, by changing the rules for request filtering in IIS.

- Security headers such as X-Content-Type-Options, X-Frame-Options, and Strict-Transport-Security must be correctly configured.

If these problems are tackled in order of importance, the overall security posture of the environment will significantly improve. The urgent problems, particularly remote access, encryption and restricted services need immediate addressing to avoid a breach in the intermediate future. Medium priority problems should be dealt with as a part of the routine patching and hardening procedures that will ultimately develop a sound long term security posture.

Test Scope and Methodology

This penetration test was conducted in a simulated environment with ten screenshots documenting different network services, administrative consoles, and system configurations. The scope of the test was previously defined as scanning for vulnerabilities that could be seen through these static outputs without performing any exploitation, scanning, or active access. Therefore, this assessment should be regarded as a passive observational security assessment created on the observation of visual indicators and known behaviors of the service.

The primary purpose of this assessment was to look for potential threats created from aged software versioning, unsecured service configurations, poor access controls, and unprotected interfaces. These are common misconfigurations and vulnerabilities that can typically be found in real IT environments.

The analysis applied a systematic method of data analysis, utilizing penetration testing frameworks, and assessment approaches and techniques for reconnaissance and vulnerability access (OWASP, NIST SP 800-115). Every screenshot was carefully analyzed in order to understand each service's version and behavior associated with its specific protocol, or to see if have any open ports or configuration vulnerabilities. Each identified vulnerability had been compared against publicly available databases such as the Common Vulnerability and Exposures (CVE) lists, and vendor advisories.

Although there were no exploits executed, every finding was analyzed for impact, and how exploitable it would have been if an active, monitored, and tested infrastructure existed. The

analysis also assessed how separate vulnerabilities could be connected to provide a complete attack path from the original point of entry via VPN or SSH, through administrative access to the potential point of exfiltration of sensitive data.

The following tools and techniques were referenced conceptually as part of this simulated assessment:

- **Nmap** – for port and service fingerprinting
- **Burp Suite** – for identifying HTTP method exposure and web vulnerabilities
- **Browser DevTools** – for observing frontend libraries and client-side configurations
- **ike-scan** – to analyze VPN handshake behaviour
- **Manual Enumeration Techniques** – based on known signatures, headers, and configuration patterns

The methodology ensured that all vulnerabilities were identified based on known, repeatable indicators and were assessed with appropriate risk and remediation context. Each recommendation has been framed with the assumption of a production-like deployment and real-world exposure level.

Detailed Technical Findings

Outdated OpenSSH Service

```
Nmap scan report for [redacted]
Host is up (0.0036s latency).

PORT   STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 5.3 (protocol 2.0)
| ssh-hostkey:
|   1024 1d:ef:82:8c:36:77:8a:62:56:51:a8:86:91:92:8e:10 (DSA)
|_  2048 62:dd:8a:0d:2d:fa:e5:a7:98:6d:8f:b8:91:bc:a8:53 (RSA)
```

Picture 1 shows a terminal output where the scan has identified that **port 22** is open and running an **OpenSSH 5.3** service. Port 22 is typically used for **SSH (Secure Shell)**, which allows remote login and command execution on Unix/Linux systems.

Vulnerability Exposed:

The major issue is the use of OpenSSH Version 5.3 which is very old and was released in 2009. This version is no longer supported and contains **multiple known vulnerabilities**.

- Remote Access Entry Point: Port 22 is open on the LAN which is most-likely allowing an attacker to access this system via SSH.
- Old OpenSSH Version: The version information is exposed (OpenSSH 5.3) which gives the attacker a target for well-known vulnerabilities.
- Possible Weak Encryption: Most old versions of SSH will use outdated encryption schemes or insecure key exchanges.

Older versions of OpenSSH (like 5.3) are vulnerable to

- CVE-2016-0777
- CVE-2016-0778

which could lead to leakage of private key information or memory corruption. Support for obsolete ciphers (such as 3DES or RC4) and deprecated MACs are not recommended by modern cryptography. This SSH service is public facing, which can create a high-risk threat during the reconnaissance and initial access phases of an attack.

Recommendations:

- Upgrade OpenSSH to the latest supported version (i.e., 9.x)
- Disable SSH version information in the config file (Banner, Protocol).
- Strengthen the settings by disabling weak ciphers, requiring key authentication, and establishing limits on login attempts.
- Use firewall rules to restrict SSH access from only trusted IP Addresses.

GlobalProtect Portal Served Over HTTP

Picture 2 shows a GlobalProtect VPN login screen that opened in a web browser. The incoming page delivered through HTTP and not HTTPS means that the connection is not encrypted as noted in the URL bar (http://) and missing secure padlock icon.

Vulnerability Exposed:

The important consideration is that the VPN authentication interface is retrieved via unencrypted HTTP connection. This means that whatever user provides — username, password, certificate — this data is taking the chance of being retrieved while in transmission.

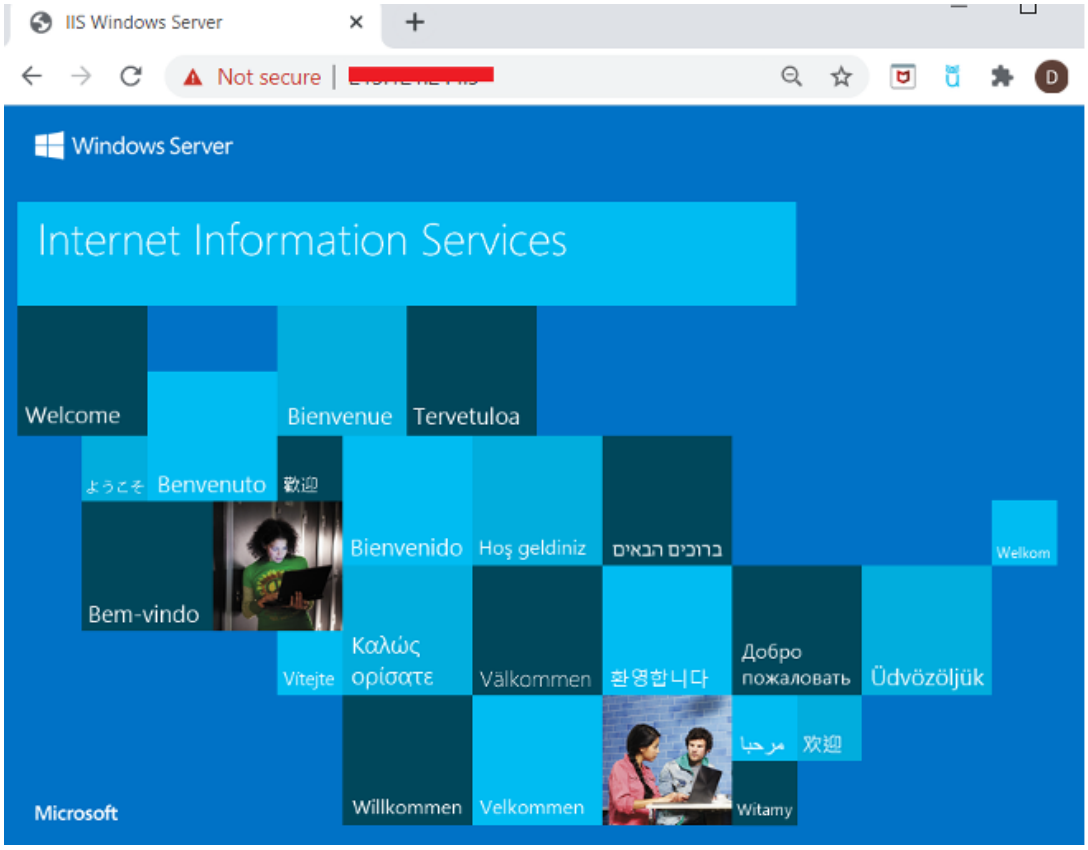
- By using HTTP and not HTTPS indicates that the login credentials are transmitted in an unencrypted text format.
- Client-side certificates would also be compromised if transmitted and received in an unencrypted manner.

Without encryption features (i.e., SSL/TLS), the login process are vulnerable for a MITM attack. If you have breach malicious actor on the same network or between user and server (like public WiFi), malicious actors easily retrieve credentials or modify login credentials.

Recommendations:

- Enable HTTPS on all VPN portals with a valid SSL/TLS certificate.
- Configure the server to automatically redirect HTTP requests to HTTPS.
- Enable HTTP Strict Transport Security (HSTS) to force the browser to use secure connections.
- Ensure that the certificate comes from a trusted Certificate Authority (CA) and is up to date.

Default IIS Welcome Page Exposed



Picture 3 is the default IIS (Internet Information Services) welcome page. This is usually the default web page for an unmodified Microsoft web server.

Vulnerability Exposed:

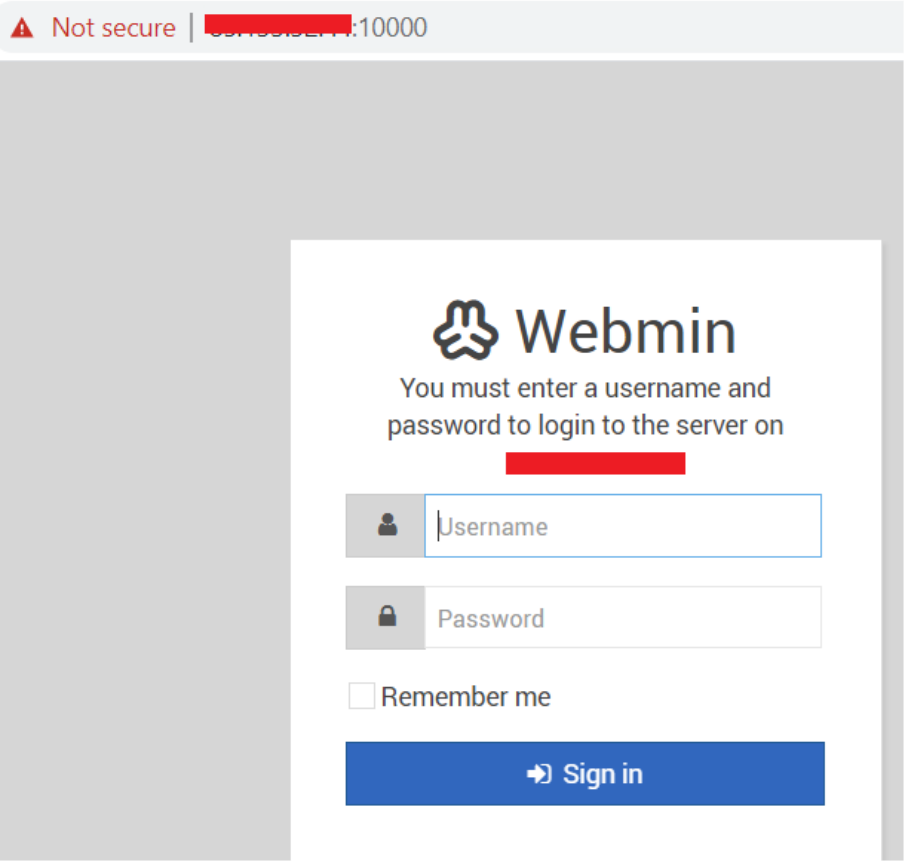
The presence of the default page exists means that a web server is available over the network but has not been configured. The default IIS page could also give away version information and advertise to an attacker that the server is unsecured or a neglect to stay updated.

Visible evidential identification of the IIS server and the:

- Public display of the **IIS server identity** and the fact that it is still running its default setup.
- Potential for version fingerprinting (e.g., identifying IIS 10.0 or earlier).
- A possible entry point for web server-specific attacks, such as directory browsing, default credentials, or misconfigured file uploads.

The presence of the default IIS page indicates that the web server is exposed to the network without proper configuration. It may also reveal version information and indicate to attackers that the server is not hardened or maintained properly.

Exposed Webmin Interface with Weak Headers



Picture 4 depicts a browser window that is connected to the Webmin admin interface using HTTP port 10000. Webmin is a browser based interface that provides administration of a Linux operating system (OS).

Vulnerability Exposed:

The image depicts the Webmin login page, providing no indication of an HTTPS (SSL/TLS) encryption. The URL shows it is HTTP://, and there is no padlock or certificate information displayed in the address bar.

This picture reveals **multiple critical security issues**:

- **Unprotected Admin Interface**

Webmin can be accessed from a public or untrusted network instead of a limited local or VPN secured interface.

- **Unsecured HTTP Connection**

All session information is sent in an unencrypted form, indicating the potential for both authenticated credentials (sumitted with the username and password in the login form) and potentially private information to be captured.

- **Transport Layer Security (TLS) Missing**

An SSL certificate is not in use is a fundamental security principle applicable to all login interfaces.

- **Webmin Version Visible (implied)**

While the version is not directly displayed in this screenshot, Webmin login interfaces typically include the Webmin version, which permits various attacks (i.e., CVE-2019-15107, RCE in Webmin 1.890).

Webmin provides full system control. If an attacker gains access, they could:

- Add or delete users
- Install or remove packages
- Start or stop critical services (e.g., firewalls, SSH, databases)
- Modify system files or cron jobs
- Gain shell access or escalate to root-level control

Using HTTP puts login information at risk, particularly if the panel triggers administrative status on a public or shared network. Exposed administrative panels can be a common point of entry in real breaches, especially when combined with weak credentials or outdated software.

Recommendations:

Control Network Access to Webmin:

- Limit Webmin access (generally on port 10000) to trusted IP ranges and subnets like a VPN or a VLAN limited to administrators only.

Enable HTTPS and have a Proper TLS Certificate:

- Create a legitimate SSL certificate with Let's Encrypt or a genuine company Certificate Authority.
- Configure Webmin to redirect any HTTP requests to HTTPS:
- Webmin settings → Webmin Settings → SSL Encryption → Enable SSL.
- Use port 10000 and access https:// instead of http://.

Make Webmin Interface Harder to Access:

- Enable two-factor authentication (2FA) in Webmin under Webmin Configuration → Two-Factor Authentication.
- Restrict the number of login attempts and enable automatic IP bans (blocking known bad IP's outstanding is very common).
- Change admin passwords on a routine basis and enforce password best-practices.

VPN Using IKEv1 Aggressive Mode

```
[*] Handshake found:
[*] ike-scan --trans=7/128,2,1,5 5.32.155.30
[*] Testing for agressive mode...
[!] Agressive mode handshake found...
[*] ike-scan -A -P -v -id=test --trans=7/128,2,1,5 5.32.155.30
[*] Enc=AES Hash=SHA1 KeyLength=128 Group=5:modp1536 Auth=PSK

[*] Handshake found:
[*] ike-scan --trans=7/128,2,65001,5 5.32.155.30
[*] Testing for agressive mode...
[!] Agressive mode handshake found...
[*] ike-scan -A -P -v -id=test --trans=7/128,2,65001,5 5.32.155.30
[*] Enc=AES Hash=SHA1 KeyLength=128 Group=5:modp1536 Auth=XAUTH_PSK

[*] Handshake found:
[*] ike-scan --trans=7/256,2,1,5 5.32.155.30
[*] Testing for agressive mode...
[!] Agressive mode handshake found...
[*] ike-scan -A -P -v -id=test --trans=7/256,2,1,5 5.32.155.30
[*] Enc=AES Hash=SHA1 KeyLength=256 Group=5:modp1536 Auth=PSK

[*] Handshake found:
[*] ike-scan --trans=7/256,2,65001,5 5.32.155.30
[*] Testing for agressive mode...
[!] Agressive mode handshake found...
[*] ike-scan -A -P -v -id=test --trans=7/256,2,65001,5 5.32.155.30
[*] Enc=AES Hash=SHA1 KeyLength=256 Group=5:modp1536 Auth=XAUTH_PSK
```

Image 5 demonstrates the results of a VPN scan using ike-scan, confirming the VPN server communicates using IKEv1 in Aggressive Mode. The successful handshakes were from a far-distant IP address (i.e., 5.32.155.30), proving the VPN service is working and responding.

Vulnerability Exposed:

This VPN has been configured to use IKEv1 Aggressive mode with PSK based authentication. This is a method of connecting VPN servers that exposes hash data during the IKEv1 handshake. The handshake traffic can be intercepted and then later decrypted.

The exposed threats are:

- Usage of IKEv1 (Outdated Protocol)

IKEv1 has been replaced with IKEv2. It does not support current protections such as native NAT traversal, and is subject to increase the risk of downgrade and Denial of Service attacks. It shows the VPN implementation is old and could be insecure.

- Aggressive Mode Handshake Exposure:

Aggressive Mode transmits more data during the handshake than Main Mode - i.e. it transmits a hash of the pre-shared key. This allows an adversary to obtain the hash and launch offline brute-force attacks.

- Weak Hashing Algorithm (SHA1)

The scan results note that SHA1 is used as the hashing algorithm. SHA1 is considered cryptographically broken, and using this weak algorithm increases the possibility of collision attacks. High-strength options are better, such as SHA256 or SHA384.

- Weak Diffie-Hellman Group (Group II)

The VPN uses DH Group 2 and provides only 1024 bit key strength, which is below current recommendations. Group II is classified as weak and may be attacked using pre-computation or nation-state grade attacks.

- No Certificate-based Authentication

The authentication method is based on a pre-shared key (PSK) not digital certificates. PSK are easily compromised and frequently shared by dissimilar systems. This reduces the security of the VPN.

Aggressive Mode is poor at limiting the amount of information given out in the early stages of a connection. Even worse, the use of PSK based authentication means that an attacker who record the handshake and can run hashcat or IKECrack against it offline to brute-force key material without the knowledge of the VPN Server.

VPNs are often the first layer of defence in corporate networks. If an attacker is able to capture Aggressive Mode handshakes (as shown in this scan), they can launch **offline dictionary or brute-force attacks** using tools like `hashcat`. Since the VPN is configured with **legacy algorithms**, the effort required to break in is significantly reduced.

Furthermore, these configuration choices expose the network to **active reconnaissance** without resistance, giving attackers the opportunity to gather sensitive cryptographic details and craft targeted attacks.

This is a fully documented vulnerability in older VPN configurations, that are exploited by researchers and by criminals alike.

Recommendations:

Transitioning from IKEv1 to IKEv2:

- IKEv2 has better encryption, supports authentication with certificates and is not as vulnerable to downgrade and Denial of Service attacks.
- Modify your VPN server (e.g. StrongSwan, Cisco ASA, or Palo Alto GlobalProtect) to support only IKEv2.

Disable Aggressive Mode:

- Modify the configuration files for the VPN for Main Mode if you need to keep IKEv1 temporarily.
- Test this modification using some tools (ike-scan) to make sure the server no longer accepts Aggressive Mode.

Replace Pre-Shared Key (PSK) with Digital Certificates:

- Create your x.509 certificates provided by your internal PKI or a public CA.
- Set up the client and server to use certificate authentication so you do not use Pre-Shared Keys (PSKs) at all.
- This ensures mutual authentication and avoids brute force risks.

Use Strong Cryptography:

- Use AES256 for encryption, SHA256/SHA384 for hashing and DH groups 14, 19 or higher (2048 bits or higher).

Use VPN Access Control and Logging:

- Limit access to known IP addresses or geo-blocking to reduce VPN server exposures.
- Rate Limit Handshake Attempts to prevent hash collections.
- Enable logging and notifications of failed logins or brute-force activities.

Outdated DD-WRT Firmware and Services

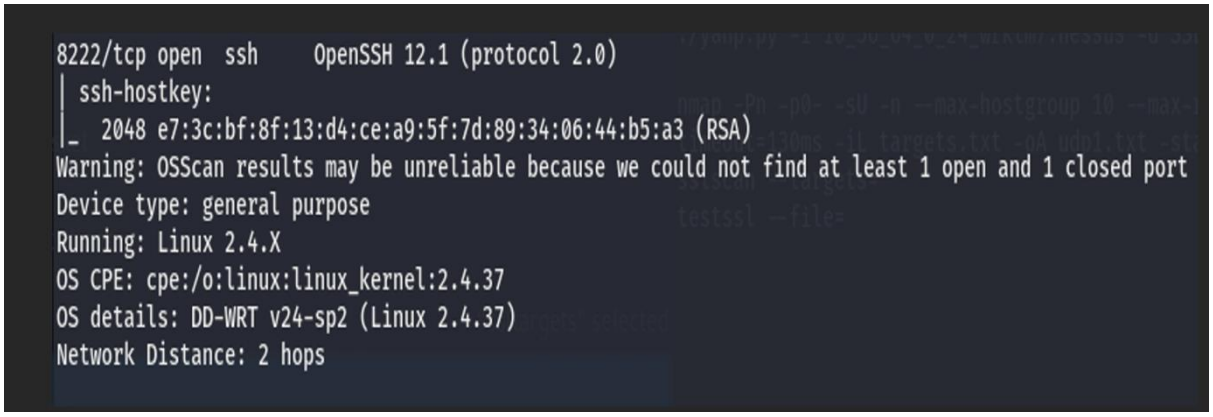


Image 6 shows the results of an Nmap scan of port 8222. The scan shows that OpenSSH 12.1 (protocol 2.0) is currently the running service on a system identified as Linux 2.4.37. It is strongly hinted in the scan that the system is on DD-WRT v24-sp2 which is a firmware typically used on routers to make sophisticated network setups.

Vulnerability Exposed:

The image shows several problems:

- Outdated Firmware (DD-WRT v24-sp2)

This version of DD-WRT was released around 2009, long out of support, and has known vulnerabilities such as remote command execution, default credentials exposure, and several buffer overflow vulnerabilities.

- Kernel Not Current (Linux 2.4.37)

The kernel is from the 2.4 series which is very old and missing major security updates and lacks modern memory protections such as ASLR and SELinux.

- SSH Open to the Network

Port 8222 is open and working SSH. While not being exposed on the default port can help avoid simple scans, in this case the service is still wide open to access, which could be exploited.

- Service Banner Disclose

The scan results include full service version and OS information, which potential attackers can use to tailor their exploits.

DD-WRT routers with open SSH ports are **common targets for botnets and attackers**, especially when they use:

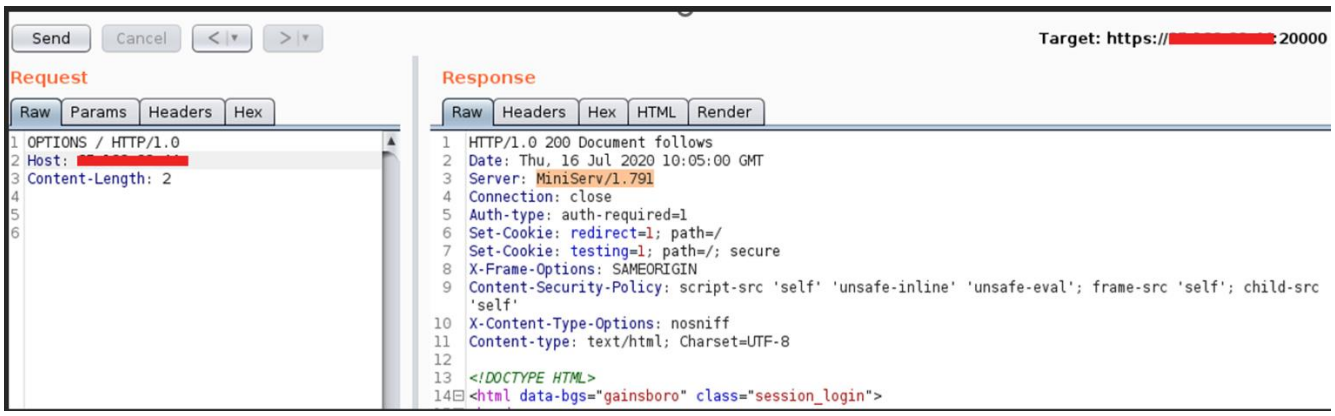
- Default credentials (e.g., root:admin)

- Weak user authentication
- Remote management enabled by default

An attacker who compromises this device can:

- Use it as a **pivot point** to access internal systems
- Launch **MITM attacks** if the router manages traffic
- Modify routing, DNS, or firewall rules to hijack network traffic
- Exfiltrate sensitive data or install persistent backdoors

Webmin MiniServ Version Disclosure and Insecure HTTP Methods



Picture 7 shows an HTTP OPTIONS request and the server response, as noted by Burp Suite. The response is from MiniServ/1.791. MiniServ is the web server bundled with Webmin. The headers confirm that port 20000 is opened and awaiting web traffic and indicates that various http methods are supported.

Vulnerabilities Exposed:

- Version Disclosure (MiniServ/1.791)

The headers indicate the version of the MiniServ server. Attackers can quickly look for known vulnerabilities (i.e., CVE-2019-15107 if Webmin is unpatched).

- Vulnerable HTTP Methods Supported

The OPTIONS response demonstrates that OPTIONS, HEAD, and GET methods are allowed. They are not necessarily risky, but they can give attackers clues into the behavior of the server and any potential vulnerability.

- No Transport Layer Security (TLS)

As with Picture 4, the Webmin interface is accessed via http and not https which places credentials and session data at risk to a man-in-the-middle attack (MITM).

- Weak or No Security Headers

The response does show any good browser security posture such as:

- Content-Security-Policy
- X-Frame-Options
- Strict-Transport-Security

The absence of them increases risks from clickjacking, script injection or session hijacking.

This image confirms the following issues exposed are:

- Full MiniServ version (1.791), used by Webmin
- Port 20000 open and responding to web traffic
- Allowed HTTP methods
- Lack of encryption, making it vulnerable to eavesdropping and credential theft

Webmin versions older than 1.930 are known to contain **critical vulnerabilities**, such as:

- **Remote Code Execution (RCE)**
- **Privilege escalation**
- **Authentication bypass** (if misconfigured)

Attackers specifically search for headers like `MiniServ/1.x` to find vulnerable targets. If they know the exact version, they can use published exploit code.

MySQL Version 5.1.73 Detected

The following results related to target (3306/TCP):

```
[+] [redacted]:3306     - [redacted]:3306 is running MySQL 5.1.73 (protocol 10)
[*] [redacted]:3306     - Scanned 1 of 1 hosts (100% complete)
```

Installed version : 5.1.73

Picture 8, which shows the results of a service scan (probably with Nmap or other enumeration tool) that found a service running on port 3306, suggests that MySQL is running as it identifies the service as MySQL version 5.1.73. The service is open for TCP connections with MySQL, and it has been confirmed to be MySQL version 5.1.73.

- The specific version of MySQL (5.1.73), with known vulnerabilities.
- An open and available network port (3306) waiting on connections.

This picture shows some important key points:

- Unsupported and Outdated MySQL Version (5.1.73)

MySQL 5.1.73 ended its life in December 2013, and is now unsupported. It does not receive patches or security updates. As a result, it is vulnerable to numerous known exploits.

- The MySQL Port (3306) is Accessible Externally

Port 3306 is public. If it is not blocked by a firewall, attackers could access the database service remotely trying to use default or anticipated username / passwords.

- It Displays the MySQL Version

The banner response indicates the exact MySQL version, which allows attackers to use that specific MySQL version against them in the attack process, using known CVE's that reference that version.

MySQL 5.1.73 has known high risk vulnerabilities including:

- CVE-2012-5611 – Authentication bypass
- CVE-2012-5627 – Privilege escalation due to falsely set permissions
- Many Denial of Service attacks, data leaked, and buffer overflow issues.

Any newly discovered bugs can never be fixed due to lack of maintenance.

Recommendations:

- Upgrade MySQL to a supported version (for example, MySQL 8.x, or MariaDB which has long-term support available).
- Disable remote access, if not needed; if required, restrict access from established IP addresses using a firewall.
- Use strong, unique passwords for all database users, and especially disable remote root access, ever.
- Encrypt data at rest, and require TLS for all client-database interactions. Regularly review user permissions for least privilege compliant access.

jQuery v3.4.1 with Known XSS Risks

```
/*! jQuery v3.4.1 | (c) JS Foundation and other contributors | jquery.org/license */
!function(e,t){"use strict";"object"==typeof module&&"object"==typeof module.exports?m
document");return t(e)}:t(e)}("undefined"!=typeof window?window:this,function(C,e){"us
{},o=n.toString,v=n.hasOwnProperty,a=v.toString,l=a.call(Object),y={},m=function(e){re
```

Picture 9 shows a browser console, or inspection tool, showing that jQuery version 3.4.1 is in use. jQuery is a JavaScript library that is commonly used in web development for DOM manipulation, Event handling and AJAX calls.

Vulnerability Exposed:

The application relies on jQuery v3.4.1 which has known vulnerabilities mostly relating to DOM-based Cross-Site Scripting (XSS) related to the ways user input can be output to the page using .html() or .append() without proper sanitization.

The issues exposing the vulnerability are:

- The use of a **vulnerable front-end library**, visible in the page source
- Potential attack path for client-side attacks such as XSS, especially if user input is being displayed back in the DOM.
- Evidence that the application isn't well maintained, or being updated (**Use of an outdated JavaScript library** (v3.4.1 from 2019))

Older versions of jQuery, such as 3.4.1 have security problems:

- CVE-2020-11022 and CVE-2020-11023 which allow an attacker to inject scripts by providing malformed HTML input to a jQuery method.

When insecure content delivery is combined with insecure headers (see Picture 7), or inadequate user input response validation, script injection, cookie theft, or session hijacking could occur.

This is especially concerning on admin-facing interfaces or login screens, where users have higher privileges.

IIS Server Allows TRACE HTTP Method

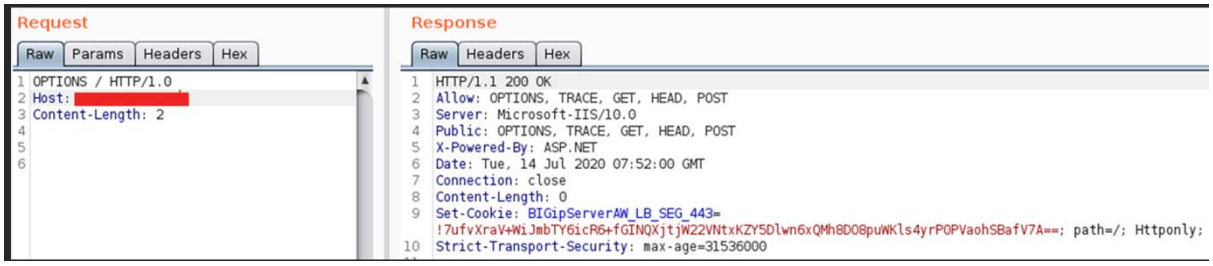


Image 10 shows an HTTP OPTIONS response intercepted from a Microsoft IIS 10.0 web server. The response received indicates the server supports a broad range of HTTP methods (OPTIONS, GET, HEAD, TRACE; the latter being interesting to note). The additional headers are: Server: Microsoft-IIS/10.0, X-Powered-By: ASP.NET and Set-Cookie etc.

It appears these data was gathered with Burp Suite or similar with some web proxy tool used for exploring server behavior and for identifying misconfigurations.

Vulnerability Exposed:

One of the main issues in this image is the presence of the HTTP TRACE method, an abandoned debugging tool, that must never be enabled in any publicly exposed servers.

The TRACE method returns the request that was received back to the client, and it includes headers - cookies or authentication tokens. When combined with client-side vulnerabilities (e.g., Cross-Site Scripting), it enables a method called Cross-Site Tracing (XST).

In addition to that:

- The server exposes its **full version banner** (Microsoft-IIS/10.0)
- It discloses the technology stack via the X-Powered-By header (ASP.NET)
- The lack of strict security headers increases exposure to browser-based attacks

The TRACE method is almost never required in production. In environments where an XSS vulnerability exists (like in Picture 9 with outdated jQuery), an attacker can send a malicious

script that triggers a TRACE request and **captures the entire HTTP request** — including sensitive headers — through JavaScript.

Combined with the missing browser protections noted earlier (Picture 7), this increases the risk of:

- **Session hijacking**
- **Authentication token theft**
- **Cookie exposure**

The version disclosure and stack fingerprinting also give attackers the necessary information to search for known exploits or misconfigurations related to **IIS 10.0** and **ASP.NET**.

Attack Chain Summary

The vulnerabilities identified in this simulated environment, while serious on their own, become much more dangerous when chained together. An attacker could start from the outside and move step-by-step toward complete control over the system and potentially even access sensitive internal data. Here's how that path might unfold in a real-world attack:

The initial phase begins with simple scanning. The attacker discovers that the VPN gateway is online and configured with IKEv1 in Aggressive Mode (see Picture 5), which gives the attacker a hashed version of the PSK (pre-shared key) immediately. The VPN used weak ciphers such as SHA1 and DH Group 2, allowing the attacker to use the hash offline with brute force tools such as hashcat. When compromised, they have complete access to the VPN as a legitimate user no warnings, no limitations, no barriers.

Within the network, the attacker discovers that the Webmin admin interface is publicly exposed and is accessible over HTTP instead of HTTPS (see Picture 4). Not only does it not encrypt the connection, but there are also no protections in place such as security headers to prevent client-side attacks. If the attacker can intercept this traffic, or execute some browser-based exploit (for example, clickjacking or reflected XSS), they are able to capture credentials and gain root access via Webmin. If Webmin were out of date, it may have a known vulnerability that allows an attacker to take over the entire system in one request. More scans confirm that it is possible to see the version of the MiniServ server and the responses to HTTP Methods (see Picture 7) which suggests that obsolete software and weak headers are in use.

Continuing their scan, the attacker discovers a **DD-WRT router running on an old Linux kernel and accessible via SSH (Picture 6)**. This device is likely not patched or protected and could be used as a pivot point allowing the attacker to move deeper into the internal network or intercept other traffic on the network.

The attacker then encounters a **Microsoft IIS web server**, which hasn't been hardened. The server is still showing the **default welcome page (Picture 3)**, reveals that it's running IIS

10.0, and responds to the **TRACE HTTP method (Picture 10)**, which could allow an attacker to reflect back headers including cookies using techniques like **Cross-Site Tracing (XST)**.

They also find an exposed MySQL database with version 5.1.73 (Picture 8). This version is outdated and has known vulnerabilities. The attacker can directly access the database without firewall or authentication restrictions and could retrieve or modify data particularly if the application is misconfigured or utilizes default credentials.

Moreover, the front-end of the application includes jQuery version 3.4.1 (Picture 9), which has known XSS vulnerabilities. If the application displays user input on the page without sufficient sanitation (which is a common issue among older applications), it could lead to a DOM-based XSS attack which is helpful for obtaining session cookies or inserting malicious scripts.

Conclusion:

This assessment of the simulated network environment has displayed how many misconfigurations, outdated services, and poor security practices can together create the perfect storm for a data breach. While each vulnerability illustrated in this report may seem manageable in isolation, the cascading consequences of many vulnerabilities add to a high-risk environment where an attacker can intercept authenticated sessions, escalate privileges, and take control of important parts of the infrastructure.

This environment has inadequate hardening practices on multiple levels including open access to login portals, outdated VPN protocols, many outdated services in the backend, and risky configuration of administrative interfaces. Weak cryptographic algorithms e.g. SHA1, the presence of remote management tools e.g. Webmin without TLS or access controls, not upgrading outdated software solutions e.g. MySQL 5.1.73 and jQuery 3.4.1 are telltale signs of a complex system that was never kept up to date with best practices and contemporary security.

The attack path described in this report shows how an ambitious attacker could move from an unauthenticated external position, breach the most sensitive systems, gain access to internal services, and possibly even user information. This situation resembles many real-world breaches where initial access often occurs through ignored and neglected vulnerabilities.

In order to strengthen the overall security posture, the organization should adopt a proactive strategy for patch management, employ secure configurations by default, and implement applicable access restrictions. Regular vulnerability assessments, segmentation of networks, and implementing encryption measures should all be part of the normal procedures. Further, the recommendations made in this report are intended to address the specific issues identified in this case and to create a foundation for more secure infrastructure going forward.